Project Report: Performing Vulnerability Exploitation and Remediation Strategies

Course-end Project 1

Student Name: Mohammad Aamir Siddique

Date: February 22, 2026

---

1. Executive Summary

This project demonstrates the identification and exploitation of the **MS17-010 (EternalBlue)** vulnerability within a simulated environment. By utilizing **Nmap** for reconnaissance and the **Metasploit Framework** for exploitation, I successfully gained remote access to a Windows 10 target. The project highlights how unpatched SMB configurations can lead to total system compromise and underscores the necessity of robust remediation strateg

---

2. Project Objective & Scope

- **Objective**: To identify and exploit security vulnerabilities in network systems by simulating real-world attack scenarios.
- **Industry Relevance**: Utilizing industry-standard tools like **Nmap** for scanning, **Metasploit** for exploitation, and **Meterpreter** for post-exploitation data extraction.
- **Attacker (Kali Linux)**: `172.31.21.206`
- **Target (Windows 10)**: `172.31.16.209`

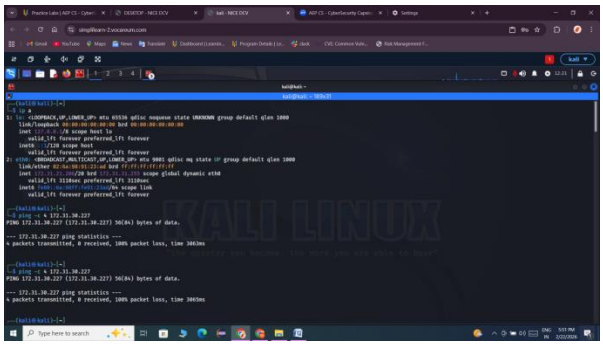
---

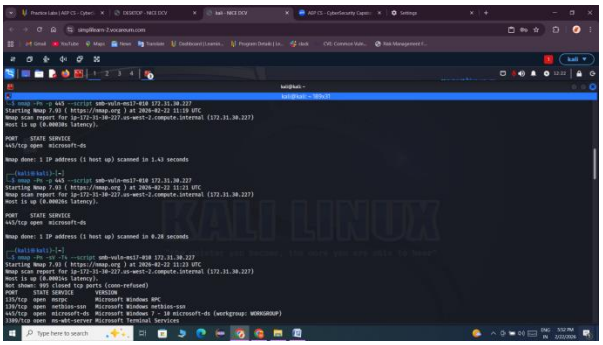
3. Phase 1: Reconnaissance and Scanning

The attack began by verifying the network path and identifying active services on the target machine.

- **Connectivity Test**: A ping test confirmed the target was reachable from the Kali attacker machine.
- **Vulnerability Scanning**: Using **Nmap**, I performed a targeted scan on **Port 445**.
- **Findings**: The scan confirmed that **microsoft-ds** (Port 445) was open and potentially vulnerable to SMB-based exploits.

Associated Image:





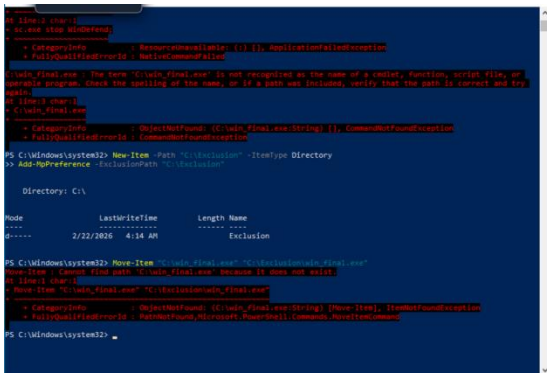
---

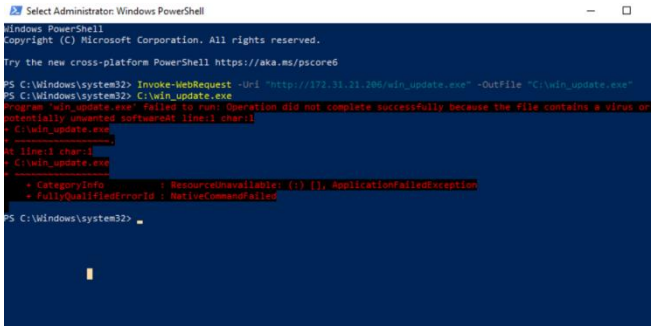
4. Phase 2: Host Preparation and Evasion

To simulate a successful penetration in a laboratory environment, host-based security measures were reconfigured via PowerShell to allow the payload to execute.

- **Security Deactivation**: Windows Firewall was disabled across all profiles, and real-time monitoring was turned off.
- **SMB Protocol**: The **SMB1Protocol** was enabled to ensure compatibility with the targeted exploit.
- **Exclusion Policy**: A dedicated directory (`C:\Exclusion`) was created and whitelisted in Windows Defender to prevent the payload from being quarantined.

Associated Image:





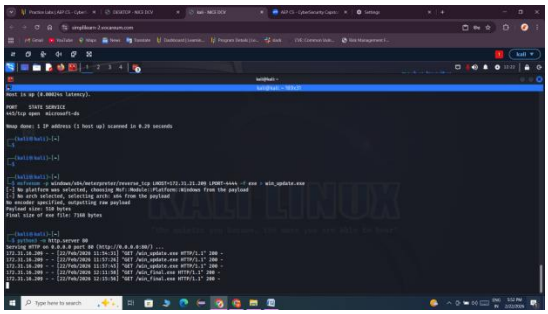
---

5. Phase 3: Weaponization and Delivery

A malicious payload was generated and delivered to the target system.

- **Payload Creation**: Using **msfvenom**, a `windows/x64/meterpreter/reverse_tcp` payload was generated and named `win_update.exe`.
- **File Transfer**: A Python HTTP server was hosted on Kali to facilitate the download.
- **Successful Download**: The target machine used `Invoke-WebRequest` to pull the payload into the exclusion directory.

Associated Image:



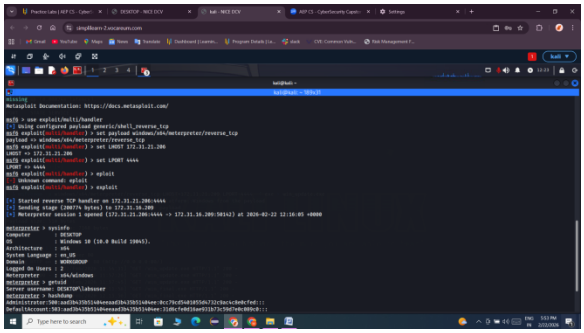
---

6. Phase 4: Exploitation (Metasploit)

The **Metasploit Framework** was utilized to catch the reverse shell.

- **Listener Configuration**: The `exploit/multi/handler` was set with the Attacker's IP (`172.31.21.206`) and Port `4444`.
- **Session Establishment**: Upon execution of the payload, a **Meterpreter session** was opened, providing full remote access.
- **System Validation**: Commands like `sysinfo` and `getuid` were used to confirm the target OS and current user context (`labsuser`).

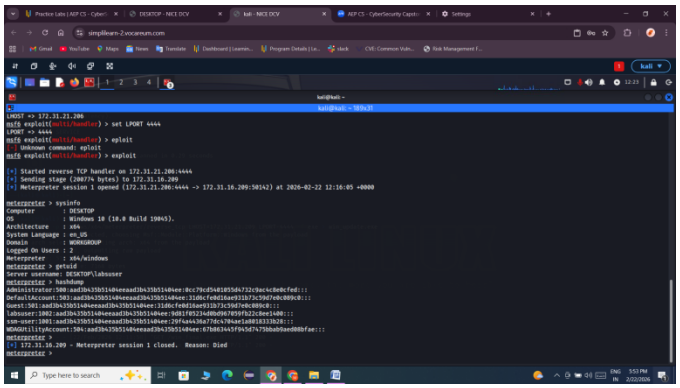
Associated Image



:

7. Phase 5: Post-Exploitation and Remediation

The final goal was to demonstrate data extraction and suggest security fixes.

- **Credential Harvesting**: The `hashdump` command was used to extract NTLM hashes for all local accounts from the SAM database.
- **Remediation Strategies**:
    1. **Patching**: Apply the **MS17-010** security update immediately.
    2. **Protocol Disabling**: Disable the outdated and insecure **SMBv1** protocol.
    3. **Endpoint Protection**: Ensure Windows Defender and Firewall are active and properly configured to block unauthorized executables.

Associated Image: